

RDP Brute Force Detected

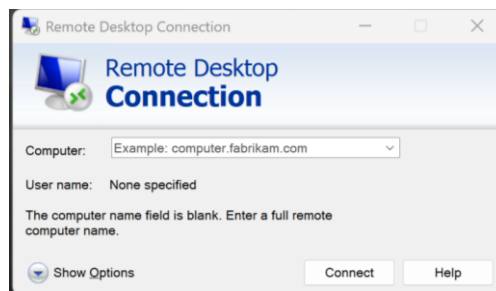


Brute force – This is a type of attack where an actor uses a trial-and-error method to gain access to a system.

- Systematic guessing for example uses automated tools to determine different combinations

RDP (Remote Desktop Protocol) – a protocol that enables users to gain access to systems remotely (windows os) through a secure channel using port 3389 by default often confused with VPN

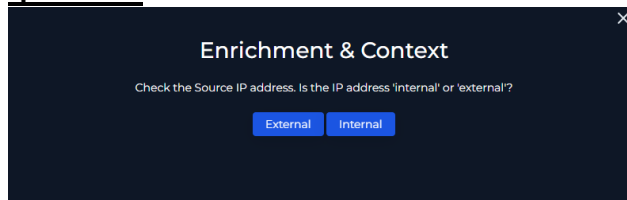
- VPN (Virtual Private Network) – allows users secure access to a private network



Incident Details

Event Time: Mar, 07, 2024, 11:44 AM
Source IP Address: 218.92.0.56
Destination IP Address: 172.16.17.148
Destination Hostname: Matthew

1) Ip Context



Source Ip = 218.92.0.56

Based on the Ip ranges/classes described below the Ip is **external**

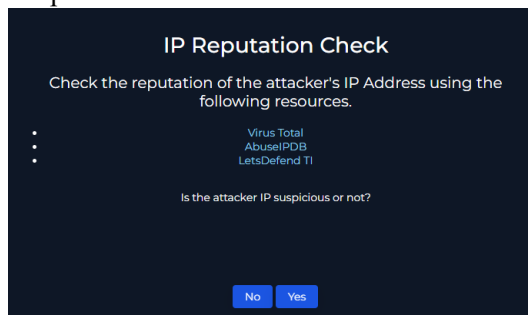
Internal Ip – assigned within a local network often referred to as private Ips
ipconfig (windows OS), ifconfig (Linux) – command used to display the private Ip address from the terminal
-Mapped to public IP addresses through network address translation (NAT) techniques

External Ip – assigned by an ISP to a network and is globally routable thus each device has an independent address

Private ip	public ip
Used with LAN or Network	Used on Public Network
Not recognized over internet	Recognized over Internet
Assigned by LAN administrator	Assigned by Service provider/IANA
Unique only in LAN	Unique Globally
Free of charge	Cost associated with using Public IP
Range -	Range -
Class A -10.0.0.0 to 10.255.255.255	Class A -1.0.0.0 to 9.255.255.255
Class B -172.16.0.0 to 172.31.255.255	Class B -128.0.0.0 to 172.15.255.255
Class C -192.168.0.0 to 192.168.255.255	Class C -192.0.0.0 to 192.167.255.255

2) IP reputation

Suspicious – YES



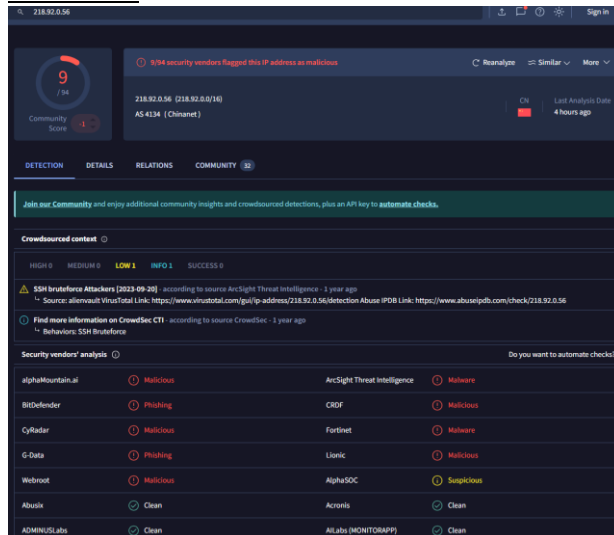
Use multiple engines to determine the status and avoid false positives/negatives

False positives – An alert or detection that flags something as malicious or suspicious, but it's benign (harmless).

False negatives- A malicious activity happens but is not detected or flagged by the security system.

This step, in incidence response can be categorized as **analysis stage**

Virus Total



AbuseIPDB

LetsDefend TI

From the attack detection details we can use the source Ip address as well as the event occurrence date to filter the results of our search

 232090 URL	 2678 IP	 376 Hash	 548 Domain
Select Filters. Clear			
Free text search 	Date range 	Search by data type IP	Search by data 218.92.0.56
Search Search			
Minimize ^			
DATE	DATA TYPE	DATA	TAG
Mar, 08, 2024, 02:33 PM	IP	218.92.0.56	Malicious
DATA SOURCE			
Anonymous			

3) Traffic Analysis

YES

Traffic Analysis

Search for the Attacker IP address in [Log Management](#). Is there a request from the Attacker IP address to the target server's SSH or RDP port?

No
Yes

Log Management – provides access to all logs within one environment on communication with any address and allows management in one place.

Using the source Ip (218.92.0.56) we can filter the results

Target server SSH (secure shell) – used to securely connect and manage remote devices on default port 22

RDP– TCP port 3389

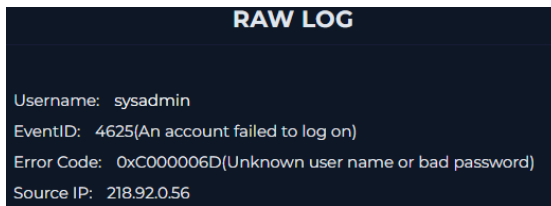
Show Filter		Search				
DATE ↑	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Mar, 07, 2024, 11:44 AM	Firewall	218.92.0.56	27876	172.16.17.148	3389	
Mar, 07, 2024, 11:44 AM	Firewall	218.92.0.56	50807	172.16.17.148	3389	
Mar, 07, 2024, 11:44 AM	OS	218.92.0.56	18845	172.16.17.148	3389	
Mar, 07, 2024, 11:44 AM	Firewall	218.92.0.56	33376	172.16.17.148	3389	
Mar, 07, 2024, 11:44 AM	Firewall	218.92.0.56	24319	172.16.17.148	3389	
Mar, 07, 2024, 11:44 AM	Firewall	218.92.0.56	10098	172.16.17.148	3389	
Mar, 07, 2024, 11:44 AM	OS	218.92.0.56	31696	172.16.17.148	3389	
Mar, 07, 2024, 11:44 AM	Firewall	218.92.0.56	32029	172.16.17.148	3389	
Mar, 07, 2024, 11:44 AM	Firewall	218.92.0.56	41175	172.16.17.148	3389	
Mar, 07, 2024, 11:44 AM	Firewall	218.92.0.56	16578	172.16.17.148	3389	

Based on the results the source Ip attempted to access the same device on address (172.16.17.148) and the logs are generated based on the firewall and OS

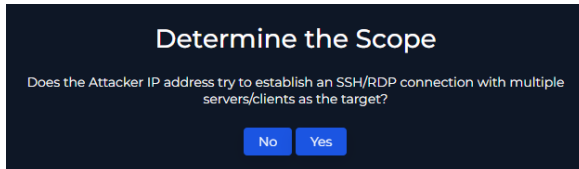
Firewall logs

RAW LOG

OS logs

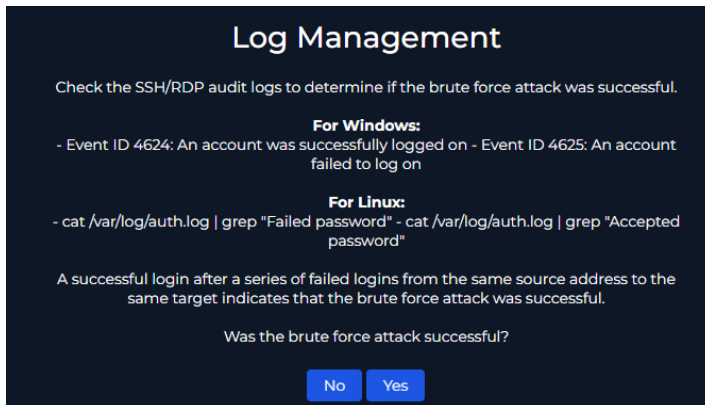


4) Scope
NO



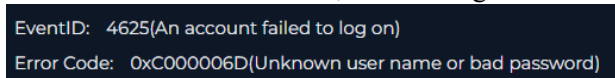
Based on the results from the log management the destination address is the same thus the attacker is only trying to connect to a single target machine (172.16.17.148)

5) Success
NO



EVENT TIME	DESTINATION DOMAIN/IP ADDRESS
Mar 7 2024 11:44:29	218.92.0.56
Mar 7 2024 11:44:32	218.92.0.56
Mar 7 2024 11:44:37	218.92.0.56
Mar 7 2024 11:44:51	218.92.0.56

From the screenshots earlier, firewall logs don't show any details on the success of the attack



OS logs however show the event id 4625 which means the attacker was unable to login thus the brute force attack was not successful

Containment

Contain the endpoint device to prevent any further attack/ penetration into the system i.e. through isolation

Endpoint Information

Host Information

Hostname: Matthew

Domain: LetsDefend

IP Address: 172.16.17.148

Bit Level: 64

OS: Windows 10

Primary User: Matthew

Client/Server: Client

Last Login: Mar, 07, 2024, 04:00 AM

Action

Containment:

Action

Containment:

Host Contained

6) Analysis note

This segment shows the lessons learnt from the attack

Analyst Note

Please enter your analysis comments.

From the analysis the attack was a true positive. The actor was not able to gain access to the system however as all login attempts failed based on the log management details. Despite this the device should be contained and the attack eradicated to prevent any further attempts to exploit the system.

301 / 3000

Next

7) Close alert

Close Alert

Event ID :

234

☒ True Positive
 ☐ False Positive

Note:

The attack is a true positive based on the logs

Close Alert